



Universidad Nacional Autónoma de México



Facultad de Ingeniería

Alumno:

Lara Hernandez Angel Husiel - 320060829

Lugo Manzano Rodrigo - 320206968

Flores Colin Victor Jaziel - 320266083

Seguridad informatica basica

Semestre: 2027-1

Actividad 2

Identificación de Activos Tecnológicos en el Sector Automotriz:
Caso VELOX Automotriz S.A. de C.V.

Fecha de Entrega:

29 de Agosto del 2026

Índice

1	Introducción	1
2	Características Generales del Sector Automotriz	1
2.1	Definición y Alcance	1
2.2	Tendencias Tecnológicas Actuales	1
2.3	Actores del Ecosistema	1
3	La Empresa: VELOX Automotriz S.A. de C.V.	2
3.1	Descripción General	2
3.2	Objetivo de negocio	2
4	Inventario de Activos Tecnológicos	2
5	Listado de Tecnología Utilizada	3
5.1	Redes y Protocolos de Comunicación	3
5.2	Plataformas de Software Empresarial	4
5.3	Infraestructura Cloud y Servidores	4
5.4	Tecnología Embebida en el Vehículo	4
5.5	Herramientas de Seguridad	5
5.6	Gestores de Bases de Datos	5
6	Endpoints, Servidores Web y APIs de VELOX Automotriz	6
6.1	Endpoints de la Organización	6
6.1.1	Endpoints de Usuario Final (IT)	6
6.1.2	Endpoints de Tecnología Operacional (OT / Planta)	6
6.1.3	Endpoints Vehiculares (In-Vehicle)	7
6.2	Servidores Web y de Aplicaciones	7
7	Diagrama de Conectividad de Activos	8
8	Análisis de Vulnerabilidades en el Stack Tecnológico	9
8.1	Infraestructura IT y Sistemas Operativos	10
8.2	Servidores Web y de Aplicaciones	10
8.3	ERP, Bases de Datos y Plataformas Empresariales	11
8.4	Infraestructura Cloud y Contenedores	11
8.5	Tecnología OT / Industrial (SCADA, PLCs y Protocolos)	12
8.6	Seguridad Perimetral y Herramientas SOC	12



8.7	Tecnología Vehicular Embebida	13
9	Actores de Amenaza Relevantes en el Sector Automotriz	14
9.1	Top 5 Actores de Amenaza en el Sector Automotriz	14
9.2	5 Eventos Recientes de Ciberataques en el Sector Automotriz	14
	Referencias	16



1. Introducción

El sector automotriz ha dejado de ser un mundo puramente mecánico para convertirse en uno de los ecosistemas tecnológicos más complejos del siglo XXI. Los vehículos modernos integran cientos de microprocesadores, millones de líneas de código y conexiones permanentes a internet, lo que los convierte en plataformas digitales sobre ruedas. Este panorama exige a las organizaciones del sector una gestión rigurosa de sus activos tecnológicos. A lo largo de este documento se analizan las características generales del sector automotriz y se presenta el perfil de *VELOX Automotriz S.A. de C.V.*, una empresa ficticia representativa, con el fin de identificar y mapear sus activos, la tecnología que emplea y la forma en que estos se interconectan.

2. Características Generales del Sector Automotriz

2.1. Definición y Alcance

El sector automotriz comprende todas las actividades económicas vinculadas al diseño, manufactura, distribución y mantenimiento de vehículos de motor. A nivel global, se estima que existen más de 1,400 millones de unidades en circulación (Upstream Security, 2024). En México, el sector representa aproximadamente el 3.5 % del PIB nacional, siendo Guanajuato, Nuevo León y Puebla los principales polos de manufactura y exportación (Cybersecurity and Infrastructure Security Agency, 2024).

2.2. Tendencias Tecnológicas Actuales

La industria vive una transformación acelerada impulsada por cuatro grandes fuerzas, conocidas como las “Cuatro Ces”:

- **Conectividad:** Módulos 4G/LTE y 5G permiten la comunicación vehículo-vehículo (V2V) y vehículo-infraestructura (V2I) en tiempo real.
- **Conducción Autónoma:** Los sistemas ADAS integran cámaras, LiDAR y radar para asistir o automatizar la conducción.
- **Electrificación:** La adopción de vehículos eléctricos e híbridos introduce nuevas arquitecturas de control y gestión energética.
- **Servicios Compartidos:** La movilidad como servicio (MaaS) demanda telemetría en tiempo real y gestión remota de flotas.

El concepto de *Software-Defined Vehicle* (SDV) está en el centro de esta transformación: el vehículo se concibe como una plataforma de hardware que puede actualizarse de forma remota (OTA), de manera similar a un teléfono inteligente (Wilhoit & Hilt, 2023).

2.3. Actores del Ecosistema

El sector automotriz moderno no se limita a los fabricantes de vehículos (OEMs). Su cadena de valor incluye a múltiples actores con roles tecnológicos bien diferenciados:



- **OEMs** (*Original Equipment Manufacturers*): Diseñan la arquitectura eléctrica y electrónica del vehículo.
- **Proveedores Tier 1 y Tier 2:** Suministran módulos y componentes embebidos (ECUs, sensores, módems).
- **Proveedores de Software:** Desarrollan sistemas operativos de vehículo, middlewares y plataformas de telemetría.
- **Concesionarios y Talleres:** Puntos de contacto directo con el cliente, con acceso al puerto diagnóstico OBD-II.
- **Plataformas de Movilidad:** Aplicaciones y servicios en la nube que consumen datos del vehículo.

3. La Empresa: VELOX Automotriz S.A. de C.V.

3.1. Descripción General

Razón social	VELOX Automotriz S.A. de C.V.
Giro	Fabricación y distribución de vehículos conectados y eléctricos
Año de fundación	2018
Sede / planta	Planta de manufactura en Guanajuato, México
Cobertura comercial	Red de concesionarios en 12 estados de la república mexicana
Servicios digitales	Plataforma de telemetría para su flota de vehículos conectados

3.2. Objetivo de negocio

VELOX Automotriz tiene como objetivo de negocio diseñar, fabricar y comercializar vehículos eléctricos conectados que ofrezcan al usuario final servicios digitales de valor agregado (monitoreo remoto, actualizaciones de funciones vía OTA, asistencia telemática), al tiempo que optimiza sus procesos de manufactura y cadena de suministro mediante la digitalización de su planta y su integración con proveedores Tier 1 y Tier 2. Dado este modelo de negocio, la disponibilidad, integridad y confidencialidad de sus activos tecnológicos son condiciones necesarias para su operación.

4. Inventario de Activos Tecnológicos

A continuación se presenta el inventario de activos tecnológicos de VELOX Automotriz. Cada activo se describe en función de su nombre, el objetivo de negocio que soporta y la forma en que hace uso de la tecnología.



#	Nombre del Activo	Objetivo de Negocio	Uso de la Tecnología
1	Servidores de Telemetría	Monitoreo en tiempo real de la flota de vehículos conectados	Recepción de datos CAN Bus vía módulo 4G/LTE; almacenados en AWS S3
2	Servidor OTA	Distribución de actualizaciones de firmware y software a los vehículos	HTTPS/TLS sobre red celular; firma digital de paquetes con PKI interna
3	Portal Web de Clientes	Punto de acceso de los usuarios a servicios digitales VELOX Connect	Aplicación web en Node.js alojada en AWS; autenticación OAuth 2.0
4	Firewall / VPN Perimetral	Proteger la red corporativa de accesos no autorizados	Fortinet FortiGate 600F; túneles VPN IPSec con concesionarios y proveedores
5	ERP SAP S/4HANA	Gestión integral de manufactura, finanzas, compras y RRHH	Instancia SAP en la nube (RISE with SAP); integración EDI con proveedores Tier 1
6	Sistema MES	Control y trazabilidad del proceso de manufactura en planta	Software FactoryTalk MES integrado con PLCs Allen-Bradley vía OPC-UA
7	SCADA Industrial	Supervisión y control de equipos críticos de producción	Red industrial Ethernet; protocolos Modbus TCP y PROFINET; HMIs Siemens
8	Active Directory	Gestión de identidades y accesos de los colaboradores	Microsoft AD DS en Windows Server 2022; políticas GPO y autenticación LDAP
9	App Móvil VELOX Connect	Brindar al cliente acceso a telemetría, soporte y servicios del vehículo	Aplicación iOS/Android; comunicación REST API con servidores de telemetría
10	Gateway OBD-II	Interfaz diagnóstica entre el vehículo y las herramientas externas	Dispositivo embebido con Wi-Fi/BLE; protocolo ISO 15765 (CAN) y ISO 14229 (UDS)
11	ECU Principal (VCU)	Coordinar las funciones críticas del vehículo eléctrico	Microprocesador Renesas RH850; firmware propietario; buses CAN FD y LIN
12	Sensores ADAS	Asistir al conductor y habilitar funciones de conducción semi-autónoma	Cámaras, radar de 77 GHz y sensor ultrasónico; procesador NVIDIA Drive Orin

5. Listado de Tecnología Utilizada

A continuación se presenta un inventario categorizado de la tecnología que emplea VELOX Automotriz en sus distintas áreas de operación (SAE International, 2021).

5.1. Redes y Protocolos de Comunicación

- **CAN Bus / CAN FD:** Red interna del vehículo para comunicación entre ECUs.
- **LIN Bus:** Protocolo de bajo costo para actuadores secundarios (ventanas, espejos).



- **Ethernet Automotriz (100BASE-T1):** Backbone de alta velocidad para ADAS y cámaras.
- **4G LTE / 5G:** Conectividad celular del vehículo para telemetría y actualizaciones OTA.
- **Bluetooth BLE 5.2:** Enlace de corto alcance con el teléfono del conductor.
- **GPS / GNSS:** Posicionamiento global para navegación y rastreo de flota.
- **Wi-Fi 6 (802.11ax):** Hotspot interno del vehículo y red corporativa en oficinas.
- **Ethernet Industrial (PROFINET, OPC-UA):** Comunicación en planta entre PLCs y sistemas MES/SCADA.
- **VPN IPsec / SSL:** Túneles seguros entre la planta, concesionarios y la nube.

5.2. Plataformas de Software Empresarial

- **SAP S/4HANA:** ERP principal para manufactura, finanzas, logística y RRHH.
- **FactoryTalk MES (Rockwell):** Sistema de ejecución de manufactura en planta.
- **Siemens WinCC:** Software SCADA para supervisión de líneas de producción.
- **Microsoft Active Directory:** Gestión de identidades y control de acceso corporativo.
- **ServiceNow:** Plataforma ITSM para gestión de incidentes y cambios.
- **Jira / Confluence:** Gestión de proyectos y documentación técnica de ingeniería.

5.3. Infraestructura Cloud y Servidores

- **Amazon Web Services (AWS):** Cómputo en nube (EC2), almacenamiento (S3), base de datos (RDS) y IoT Core para telemetría.
- **Kubernetes (EKS):** Orquestación de contenedores para los microservicios del portal VELOX Connect.
- **Servidores HPE ProLiant:** Infraestructura física on-premise para AD, MES y respaldo.
- **PKI Interna (EJBCA):** Infraestructura de clave pública para firma de actualizaciones OTA y certificados de vehículo.

5.4. Tecnología Embebida en el Vehículo

- **Renesas RH850 / R-Car:** Microcontroladores para ECUs de powertrain y seguridad funcional (ASIL-D).
- **NVIDIA Drive Orin:** SoC de inteligencia artificial para el procesamiento de sensores ADAS.



- **Qualcomm Snapdragon Automotive:** Plataforma para el sistema de infoentretenimiento y conectividad celular.
- **AUTOSAR Classic / Adaptive:** Capa de abstracción de software estándar para el software embebido.
- **RTOS (FreeRTOS / QNX):** Sistemas operativos de tiempo real para ECUs de control crítico.

5.5. Herramientas de Seguridad

- **Fortinet FortiGate 600F:** Firewall de nueva generación (NGFW) con inspección SSL y detección de intrusiones (IDS/IPS).
- **CrowdStrike Falcon:** Plataforma EDR para endpoints corporativos.
- **Upstream Security Platform:** Monitoreo de ciberseguridad específico para la flota vehicular (Upstream Security, [2024](#)).
- **HashiCorp Vault:** Gestión segura de secretos, tokens y credenciales de infraestructura.
- **SIEM (Splunk Enterprise):** Correlación y análisis centralizado de eventos de seguridad.

5.6. Gestores de Bases de Datos

- **PostgreSQL 17 (AWS RDS):** Base de datos relacional principal para el portal VELOX Connect y los microservicios de citas, usuarios y concesionarios. Alojada en Amazon RDS con replicación Multi-AZ y cifrado AES-256 en reposo.
- **SAP HANA 2.0 SPS07:** Base de datos en memoria (in-memory) que sirve como motor de persistencia y analítica del ERP SAP S/4HANA. Soporta procesamiento OLTP y OLAP simultáneo sobre los datos de manufactura, finanzas y cadena de suministro.
- **Redis 7.2 (AWS ElastiCache):** Almacén de datos clave-valor en memoria utilizado como caché de sesiones de la app web, colas de mensajes de telemetría en tiempo real y gestión de tokens JWT. Configurado con modo clúster y TLS obligatorio.
- **MongoDB Atlas 7.0:** Base de datos documental NoSQL empleada para almacenar los documentos de telemetría vehicular (series de tiempo: batería, GPS, powertrain). Su esquema flexible permite ingerir los distintos payloads MQTT enviados por el TCU de cada modelo de vehículo.
- **InfluxDB 3.0 (AWS EC2):** Base de datos de series temporales dedicada al almacenamiento de métricas de sensores IoT de planta (temperatura de soldadora, vibración de robot, consumo energético). Integrada con Grafana para dashboards de producción en tiempo real.



6. Endpoints, Servidores Web y APIs de VELOX Automotriz

La infraestructura digital de VELOX Automotriz está compuesta por tres capas de exposición que es importante identificar con precisión: los **endpoints** (dispositivos y nodos que generan o consumen datos), los **servidores web y de aplicaciones** (que alojan los servicios públicos e internos), y las **APIs e interfaces de integración** (que permiten la comunicación entre sistemas). A continuación se detalla cada capa.

6.1. Endpoints de la Organización

Un endpoint es cualquier dispositivo o nodo que se conecta a la red de la organización y puede ser origen o destino de tráfico. VELOX cuenta con tres categorías de endpoints bien diferenciadas.

6.1.1. Endpoints de Usuario Final (IT)

Endpoint	Cantidad aprox.	Sistema Operativo	Gestión
Laptops corporativas	420 unidades	Windows 11 Pro	Microsoft Intune (MDM)
Estaciones de trabajo ingeniería	85 unidades	Windows 11 / Ubuntu 22.04 LTS	Active Directory + GPO
Smartphones corporativos	210 unidades	iOS 17 / Android 14	Microsoft Intune
Tablets de planta (operadores)	60 unidades	Android 13 (modo quiosco)	MDM Jamf
Teléfonos IP (softphones)	350 extensiones	Cisco IP Phone / Webex	Cisco Unified CM

6.1.2. Endpoints de Tecnología Operacional (OT / Planta)

Endpoint OT	Cantidad aprox.	Función	Protocolo
PLCs Allen-Bradley ControlLogix	32 unidades	Control de robots de ensamblaje	EtherNet/IP, OPC-UA
HMIs Siemens SIMATIC	18 paneles	Supervisión de línea de producción	PROFINET, OPC-UA
Robots ABB IRB 6700	24 celdas	Soldadura y ensamblaje de carrocería	Ethernet industrial propietario
Sensores IoT de planta	320 nodos	Temperatura, vibración, consumo	MQTT over TLS (AWS IoT)
Impresoras industriales (etiquetado)	14 unidades	Etiquetado de piezas y VINs	TCP/IP



6.1.3. Endpoints Vehiculares (In-Vehicle)

Endpoint Vehicular	Cantidad aprox.	Función	Protocolo
ECU Principal (VCU)	1 por vehículo	Gestión de energía y modos de conducción	CAN FD, LIN
Módulo de conectividad (TCU)	1 por vehículo	Telemetría 4G/5G y OTA	MQTT/TLS, HTTPS
Unidad de infoentretenimiento (IVI)	1 por vehículo	Navegación, audio, CarPlay/Android Auto	Wi-Fi, BLE, USB
Gateway OBD-II	1 por vehículo	Diagnóstico remoto y acceso de taller	ISO 15765 (CAN), UDS
Sensores ADAS (radar, cámara, ultrasonido)	8-12 por vehículo	Asistencia a la conducción	Ethernet automotriz (100BASE-T1)

6.2. Servidores Web y de Aplicaciones

VELOX opera múltiples servidores web para atender tanto a usuarios externos (clientes y concesionarios) como a sistemas internos. La siguiente tabla describe cada servidor, su función y la tecnología base que utiliza.

Servidor	Tipo	Función	Tecnología
veloxauto.com.mx	Web público	Sitio corporativo, catálogo de vehículos y generador de cotizaciones	Nginx 1.25 + AWS CloudFront (CDN)
connect.veloxauto.mx	App web (SPA)	Portal de cliente VELOX Connect: telemetría, historial, citas de servicio	Node.js 20 LTS + React 18; alojado en AWS EKS
dealer.veloxauto.mx	Web interna (concesionarios)	Sistema de gestión de inventario y pedidos para la red de concesionarios	Apache Tomcat 10 + Spring Boot 3; HTTPS/TLS 1.3
erp-sap.velox.internal	Aplicación empresarial	Interfaz web del ERP SAP S/4HANA para usuarios corporativos	SAP Fiori (Launchpad); acceso vía VPN
ota.velox.internal	Servidor de actualizaciones	Repositorio y distribución de paquetes de firmware firmados digitalmente	Nginx + servidor de artefactos Artifactory
siem.velox.internal	Plataforma de seguridad	Consola web Splunk para análisis de logs y alertas de seguridad	Splunk Enterprise 9.x; acceso restringido por rol
api-gw.velox.internal	API Gateway	Punto de entrada centralizado para todos los microservicios internos	AWS API Gateway + Kong Enterprise

7. Diagrama de Conectividad de Activos

El siguiente diagrama ilustra cómo se interconectan los activos tecnológicos de VELOX Automotriz, agrupados en cuatro zonas lógicas: **Zona Vehículo/Cliente**, **Seguridad Perimetral**, **Zona Corporativa** y **Zona Nube**. Las flechas continuas representan conexiones directas y las flechas discontinuas indican canales de comunicación protegidos o externos.

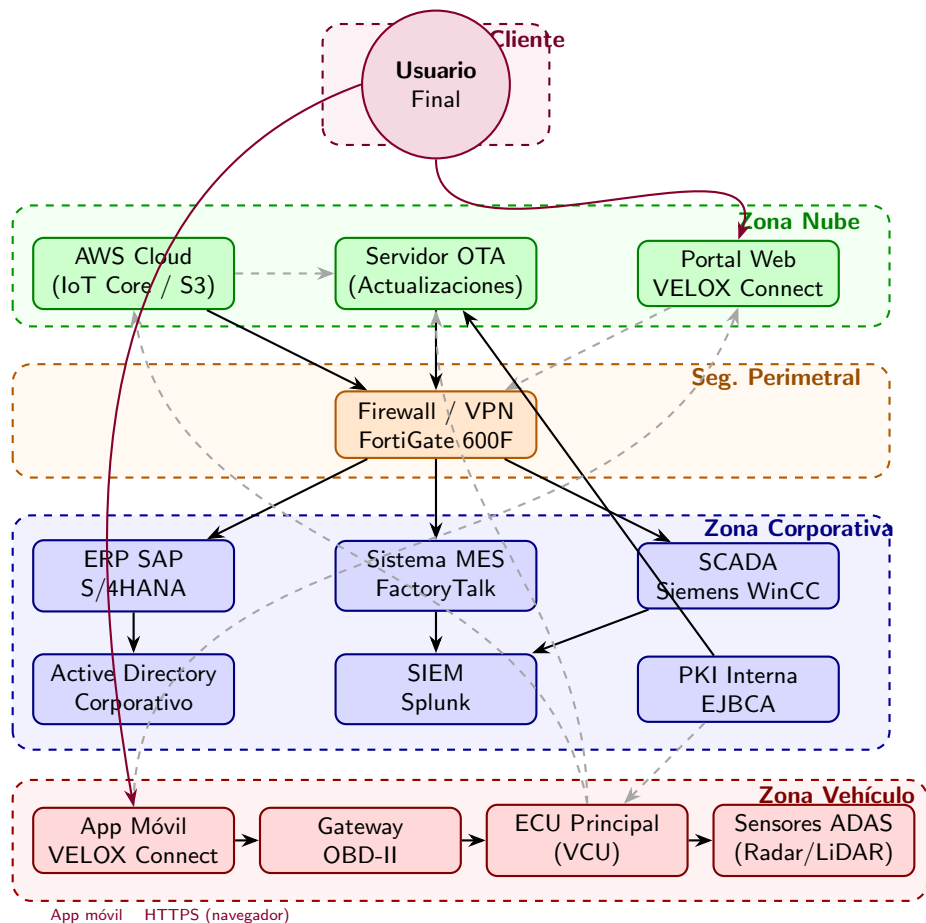


Figura 1: Diagrama de conectividad de activos — VELOX Automotriz S.A. de C.V.



8. Análisis de Vulnerabilidades en el Stack Tecnológico

El stack tecnológico de VELOX Automotriz, al ser amplio y heterogéneo, presenta una superficie de ataque considerable. A continuación se identifican vulnerabilidades reales —tanto conocidas como menos divulgadas— presentes en cada capa tecnológica, desde los sistemas operativos hasta los protocolos embebidos en el vehículo. Las vulnerabilidades se ordenan por tecnología e incluyen su identificador CVE, puntuación CVSS v3.1, categoría de seguridad según CWE, descripción técnica y recomendación de mitigación. Todas las entradas han sido verificadas en la base de datos del NIST National Vulnerability Database (National Institute of Standards and Technology, [2024](#)), complementadas con avisos de seguridad de cada fabricante (BlackBerry Limited, [2021](#); Fortinet PSIRT, [2024](#); Microsoft Security Response Center, [2024](#); Rockwell Automation, [2023](#)).

Escala de Severidad CVSS v3.1

Rango CVSS	Severidad	Descripción general
9.0 – 10.0	Crítica	Explotación inmediata sin autenticación; impacto total en confidencialidad, integridad y disponibilidad del sistema.
7.0 – 8.9	Alta	Explotación factible con baja complejidad; impacto significativo en uno o más vectores de seguridad.
4.0 – 6.9	Media	Requiere condiciones específicas o interacción del usuario; impacto parcial o limitado sobre el sistema.
0.1 – 3.9	Baja	Explotación difícil con impacto mínimo; generalmente requiere acceso local o privilegios elevados previos.



8.1. Infraestructura IT y Sistemas Operativos

CVE	CVSS	Categoría	Tecnología	Descripción	Recomendación
CVE-2021-42278 CVE-2021-42287	8.8	Escalación de privilegios (CWE-269)	Active Directory / Windows Server 2022	NoPac: el cambio de nombre de cuentas de máquina permite impersonar controladores de dominio y obtener TGT de admin de dominio.	Aplicar KB5008380 y KB5008602; activar PAC Verification en el DC.
CVE-2024-38077	9.8	Desbordamiento de búfer (CWE-122)	Windows Server 2022 (RDS)	Buffer overflow en el servicio de licencias de Windows Remote Desktop permite RCE sin autenticación.	Instalar KB5040434; si no es posible, deshabilitar el servicio de licencias RDS.
CVE-2024-0044	7.8	Escalación de privilegios (CWE-862)	Android 13 / 14	Vulnerabilidad en el sistema de instalación de aplicaciones permite a una app sin privilegios escalar a system.	Aplicar parche de seguridad Android de agosto 2024; gestionar con MDM Intune.
CVE-2022-26923	8.8	Escalación de privilegios (CWE-295)	Active Directory Certificate Services	Solicitud de certificado manipulada permite a cualquier usuario de dominio obtener un certificado de DC y autenticarse como admin.	Deshabilitar plantillas vulnerables; aplicar KB5014754.

8.2. Servidores Web y de Aplicaciones

CVE	CVSS	Categoría	Tecnología	Descripción	Recomendación
CVE-2021-23017	9.4	Desbordamiento de búfer (CWE-193)	Nginx 1.x (resolvidor DNS)	Off-by-one en el resolvidor DNS de Nginx permite RCE mediante respuestas DNS maliciosas. Afecta al servidor web corporativo y OTA.	Actualizar a Nginx $\geq$ 1.21.0; usar resolvidor DNS interno confiable.
CVE-2025-24813	9.8	RCE sin autenticación (CWE-44)	Apache Tomcat 10	Partial PUT request con un path especialmente construido permite ejecución remota de código sin credenciales.	Actualizar a Tomcat $\geq$ 10.1.35; deshabilitar Partial PUT en conf.
CVE-2023-30589	7.5	Inyección HTTP (CWE-444)	Node.js 20 LTS	HTTP Request Smuggling en el módulo nativo <code>http</code> : cabeceras malformadas permiten envenenar proxies y bypassar controles.	Actualizar a Node.js $\geq$ 20.3.1; usar Nginx como reverse proxy con validación de cabeceras.
CVE-2024-4879	9.3	Server-Side Template Injection (CWE-94)	ServiceNow (Vancouver/- Washington DC)	SSTI sin autenticación en el endpoint de la interfaz Jelly permite ejecución de código en el servidor.	Aplicar parche HF-2024-06; limitar exposición del portal ServiceNow a la VPN interna.
CVE-2023-22518	9.1	Control de acceso inadecuado (CWE-306)	Atlassian Confluence	Restablecimiento del estado de la instancia sin autenticación: permite a un atacante crear un usuario admin.	Actualizar a Confluence $\geq$ 7.19.16 / 8.5.4; aplicar regla WAF temporal.



8.3. ERP, Bases de Datos y Plataformas Empresariales

CVE	CVSS	Categoría	Tecnología	Descripción	Recomendación
CVE-2022-22536	10.0	Corrupción de memoria (CWE-444)	SAP Net-Weaver / S/4HANA (ICM)	ICMAD: corrupción de memoria en el servidor de mensajes ICM de SAP permite toma de sesión y RCE sin autenticación.	Aplicar nota de seguridad SAP #3123396 urgentemente; monitorear WAF.
CVE-2020-6287	10.0	Control de acceso inadecuado (CWE-306)	SAP Net-Weaver Application Server Java	RECON: creación de usuarios administradores sin autenticación en el portal Java de SAP mediante endpoint no protegido.	Aplicar nota SAP #2934135; deshabilitar el servicio LM Configuration Wizard.
CVE-2023-41056	8.8	Desbordamiento de entero (CWE-190)	Redis 7.2	Integer overflow en el procesamiento de comandos de lista permite escritura fuera de límites y potencial RCE en el servidor Redis.	Actualizar a Redis $\geq 7.0.15$ / $7.2.4$; limitar acceso a Redis a red interna.
CVE-2024-10978	4.2	Control de acceso inadecuado (CWE-274)	PostgreSQL 17	SET ROLE en contextos de función de seguridad DEFINER permite ejecutar sentencias con privilegios no autorizados.	Actualizar a PostgreSQL ≥ 17.1 ; auditar funciones con SECURITY DEFINER.
CVE-2021-32804	7.1	Path Traversal (CWE-22)	Node.js tar (npm pkg)	Extracción de archivos tar con rutas absolutas permite sobrescribir archivos arbitrarios del sistema. Afecta pipelines CI/CD y el servidor Artifactory.	Actualizar paquete tar a $\geq 6.1.5$; usar escaneo SCA en el pipeline.

8.4. Infraestructura Cloud y Contenedores

CVE	CVSS	Categoría	Tecnología	Descripción	Recomendación
CVE-2024-7646	8.8	Inyección de configuración (CWE-20)	Kubernetes Ingress-Nginx	Anotaciones de Ingress manipuladas inyectan directivas arbitrarias en la configuración Nginx del controlador, permitiendo escalar privilegios en el clúster.	Actualizar ingress-nginx $\geq 1.11.2$; restringir quién puede crear recursos Ingress.
CVE-2023-5528	8.8	Escalación de privilegios (CWE-59)	Kubernetes 1.28 (nodos Windows)	Montaje de volúmenes hostPath en nodos Windows permite traversal y escalación de privilegios en el nodo subyacente.	Actualizar a Kubernetes $\geq 1.28.4$; usar PodSecurity Admission para restringir hostPath.
CVE-2024-2048	8.2	Bypass de autenticación (CWE-295)	HashiCorp Vault 1.15/1.16	Petición OCSP manipulada en el motor PKI de Vault permite emitir certificados sin pasar la validación de la política configurada.	Actualizar a Vault $\geq 1.15.6$ / $1.16.2$; auditar logs de emisión de certificados.



8.5. Tecnología OT / Industrial (SCADA, PLCs y Protocolos)

CVE	CVSS	Categoría	Tecnología	Descripción	Recomendación
CVE-2023-3595	9.8	Escritura de firmware no autenticada (CWE-306)	Rockwell Allen-Bradley ControlLogix 1756	Escritura arbitraria de firmware en los módulos de comunicación ControlLogix sin autenticación, lo que permite toma de control total del PLC.	Aplicar parche Rockwell SA 2023-003; aislar la red OT con firewall industrial y deshabilitar acceso remoto al módulo.
CVE-2024-35783	9.8	RCE (CWE-78)	Siemens SINEMA Server	Inyección de comandos en la interfaz web de administración de SINEMA sin autenticación previa.	Actualizar a SINEMA Server v14 SP3; bloquear acceso externo a la consola web.
CVE-2023-28366	9.8	Pérdida de memoria / DoS (CWE-401)	Eclipse Mosquitto MQTT 2.x	Uso de memoria no liberada en el manejo de sesiones MQTT persistentes con QoS 1/2 permite agotar la memoria del broker y colapsar el servicio de telemetría.	Actualizar a Mosquitto $\geq 2.0.16$; limitar clientes concurrentes y QoS máximo.
CVE-2022-44725	9.8	Desbordamiento de búfer (CWE-122)	OPC Foundation UA .NET Standard	Heap overflow en el procesamiento de mensajes OPC-UA permite RCE en el servidor MES que consume datos de PLCs.	Actualizar OPC-UA SDK $\geq 1.04.368$; segmentar red OT de IT.

8.6. Seguridad Perimetral y Herramientas SOC

CVE	CVSS	Categoría	Tecnología	Descripción	Recomendación
CVE-2024-21762	9.6	Escritura fuera de límites (CWE-787)	Fortinet FortiOS 7.x (SSL-VPN)	Out-of-bounds write en el portal SSL-VPN de FortiGate permite RCE sin autenticación. Explotada activamente en producción.	Actualizar FortiOS $\geq 7.4.3$ de forma urgente; deshabilitar SSL-VPN si no es crítico.
CVE-2024-36985	9.0	RCE (CWE-77)	Splunk Enterprise 9.x	Inyección de comandos en lookups de búsqueda de Splunk: un usuario con rol bajo puede ejecutar código arbitrario en el servidor Splunk.	Actualizar a Splunk $\geq 9.2.2$; aplicar controles RBAC estrictos en los roles de búsqueda.
CVE-2023-4680	6.8	Lectura no autorizada (CWE-200)	HashiCorp Vault 1.14	Token de servicio Vault con política acotada puede leer secretos fuera de su namespace si existe un path de política mal configurado.	Actualizar a Vault $\geq 1.14.4$; revisar y auditar todas las políticas de acceso.



8.7. Tecnología Vehicular Embebida

CVE	CVSS	Categoría	Tecnología	Descripción	Recomendación
CVE-2021-22156	9.8	Desbordamiento de entero (CWE-190)	BlackBerry QNX RTOS 6.x / 7.x	BadAlloc: desbordamiento de entero en la función <code>calloc</code> del kernel QNX permite desbordamiento de heap y RCE en la ECU. Afecta sistemas ADAS y VCU con QNX.	Aplicar parches de BlackBerry; actualizar BSP del fabricante; aislar red in-vehicle.
CVE-2024-33066	9.8	Corrupción de memoria (CWE-787)	Qualcomm Snapdragon Auto (TCU / IVI)	Corrupción de memoria en el procesamiento de mensajes WLAN del firmware Snapdragon Automotive permite RCE remoto mediante Wi-Fi.	Actualizar firmware del SoC; deshabilitar Wi-Fi del IVI cuando no sea necesario.
CVE-2022-21449	7.5	Bypass de firma digital (CWE-347)	Java 15-17 / JWT (Bouncy Castle)	Psychic Signatures: firmas ECDSA con valor <code>r</code> o <code>s</code> igual a cero son aceptadas como válidas, permitiendo falsificar cualquier JWT firmado con ES256. Afecta la API de autenticación de la app VELOX Connect.	Actualizar Java $\geq 17.0.3$ / 11.0.15; actualizar Bouncy Castle ≥ 1.71 .
CVE-2025-2765	7.8	Credenciales embebidas (CWE-798)	Dongles CarPlay / Android Auto aftermarket	Credenciales Wi-Fi hardcodeadas en el firmware del dongle permiten acceso no autenticado a la interfaz de configuración y ejecución de código en el dispositivo conectado al puerto USB del IVI.	Prohibir dongles aftermarket en vehículos de la flota; usar solo accesorios certificados OEM.
CVE-2023-27321	7.5	Denegación de servicio (CWE-400)	OPC Foundation UA Stack (vehículo)	Consumo excesivo de recursos en el parsing de mensajes OPC-UA malformados permite DoS en el gateway de diagnóstico OBD-II que implementa OPC-UA Adaptive.	Actualizar UA Stack $\geq 1.04.362$; implementar rate limiting en el gateway OBD-II.



9. Actores de Amenaza Relevantes en el Sector Automotriz

El sector automotriz es uno de los objetivos preferidos por grupos de amenaza persistente avanzada (APT), grupos de ransomware y actores hacktivistas, debido al alto valor de su propiedad intelectual, la criticidad de sus cadenas de suministro y la creciente conectividad de sus vehículos y plantas de producción. El análisis que sigue se basa en inteligencia de amenazas publicada por MITRE ATT&CK, CrowdStrike y Mandiant (CrowdStrike, 2024; Mandiant, 2023; MITRE Corporation, 2024e).

9.1. Top 5 Actores de Amenaza en el Sector Automotriz

Actor / APT	Origen	Motivación	TTPs Principales	Víctimas en automotriz
Lazarus Group (APT38) (MITRE Corporation, 2024e)	Corea del Norte (RGB)	Espionaje tecnológico; robo de IP de EV, semiconductores y baterías para financiamiento estatal	Spear-phishing dirigido a ingenieros; watering holes en foros de manufactura; supply chain compromise; malware destructivo (WannaCry, Hermes)	Fabricantes de chips automotrices; proveedores Tier-2 de baterías EV; contratistas de OEMs coreanos y japoneses
APT41 (Double Dragon) (MITRE Corporation, 2024b)	China (MSS)	Robo de propiedad intelectual: diseños ADAS, tecnología de baterías, secretos comerciales de OEMs	Zero-days en VPN y software empresarial; living-off-the-land (LOtL); compromiso de cadena de suministro software; exfiltración silenciosa de largo plazo	Toyota, General Motors, OEMs europeos; proveedores Tier-1 con patentes de ADAS y conducción autónoma
BlackCat / ALPHV (MITRE Corporation, 2024c)	Rusia / Europa del Este (RaaS)	Extorsión económica mediante doble extorsión: cifrado de datos más amenaza de publicación	Explotación de VPNs vulnerables (FortiGate CVE-2024-21762); uso de Initial Access Brokers (IABs); cifrado de alta velocidad con Rust	Continental AG (2022): 40TB exfiltrados; múltiples proveedores Tier-1 de autopartes en EE.UU. y Europa
Akira (MITRE Corporation, 2024a)	Rusia / Europa del Este (RaaS)	Extorsión económica; especializado en manufactura e infraestructura industrial crítica	Explotación de Cisco AnyConnect VPN y FortiGate SSL-VPN; exfiltración previa al cifrado; publicación en Tor si no hay pago	Yanfeng Automotive Interiors (2023): interrumpió producción de Stellantis (Jeep, RAM) en Norteamérica
KillNet / No-Name057(16) (MITRE Corporation, 2024d)	Rusia (hacktivista pro-kremlin)	Disrupción política y económica en países que apoyan a Ucrania; daño reputacional a industrias occidentales	DDoS volumétrico coordinado vía Telegram (bots Mirai-based); ataques a portales web públicos; deface de páginas corporativas	BMW Group, Stellantis, BYD portales europeos; sitios de concesionarios en Alemania, Francia y Polonia (2022-2023)

9.2. 5 Eventos Recientes de Ciberataques en el Sector Automotriz

Los siguientes incidentes son eventos documentados y públicamente reportados que ilustran el panorama real de ciberamenazas al que se enfrenta una empresa como VELOX Automotriz (European



Union Agency for Cybersecurity, [2023](#); Upstream Security, [2024](#)).

Año	Empresa víctima	Actor	Descripción del impacto	Fuentes
Ago. 2022	Continental AG (Alemania) — Proveedor Tier-1 global de sistemas ADAS, frenos y electrónica	BlackCat / LockBit	Exfiltración de más de 40 TB de datos confidenciales: proyectos de I+D de ADAS, datos de nómina y contratos con BMW, Ford y Mercedes-Benz. Continental rechazó el pago del rescate y los datos fueron publicados en dark web. La brecha afectó la confianza de múltiples OEMs en su cadena de suministro digital.	(Abrams, 2022 ; Kovacs, 2022)
Nov. 2023	Yanfeng Automotive Interiors (China / EE.UU.) — Principal proveedor de interiores de Stellantis	Akira Ransomware	Ataque de ransomware que cifró sistemas IT de Yanfeng y exfiltró datos corporativos. Obligó a Stellantis a detener temporalmente líneas de producción de Jeep y RAM en Norteamérica durante varios días, causando pérdidas millonarias por interrupción de la cadena de suministro JIT.	(The Record by Recorded Future, 2023 ; Toulas, 2023)
May. 2023	Toyota Motor Corporation (Japón) — OEM líder mundial	Misconfiguración de nube (sin actor APT)	Exposición de datos de ubicación GPS de 2.15 millones de clientes japoneses durante casi 10 años (noviembre 2013 – abril 2023) por un bucket de AWS S3 con acceso público no intencional en la plataforma Toyota Connected. El incidente reveló la madurez operativa limitada en gestión de infraestructura cloud para datos de vehículos conectados.	(Soo, 2023 ; Toyota Motor Corporation, 2023)
Ene. 2024	Hyundai Motor Europe (Corea / Alemania) — OEM con presencia en 26 países europeos	Black Basta Ransomware	Ataque de ransomware Black Basta contra la infraestructura IT de Hyundai en Europa. Los atacantes accedieron a sistemas internos, exfiltraron contratos, datos personales de empleados y clientes, e información legal. El grupo reclamó haber robado más de 3 TB de datos.	(Toulas, 2024)
Dic. 2024	Volkswagen / Cariad (Alemania) — Subsidiary de software de VW Group (VW, Audi, SEAT, Škoda)	Misconfiguración de nube (detectado por CCC)	800,000 registros de propietarios de vehículos eléctricos del Grupo VW quedaron expuestos durante meses en un bucket de AWS S3 sin autenticación. Los datos incluían ubicación GPS precisa de los vehículos, datos de conducción e información de contacto. El Chaos Computer Club (CCC) alemán lo descubrió y notificó responsablemente a Volkswagen antes de la divulgación pública.	(Der Spiegel, 2024 ; Kovacs, 2024)

Referencias

- Abrams, L. (2022). *Continental Confirms Data Theft After LockBit Ransomware Attack*. Bleeping-Computer. Consultado el 29 de agosto de 2025, desde <https://www.bleepingcomputer.com/news/security/continental-confirms-data-theft-after-lockbit-ransomware-attack/>
- BlackBerry Limited. (2021). *QNX Software Development Platform Security Advisory – BadAlloc (CVE-2021-22156)*. BlackBerry Limited. Consultado el 29 de agosto de 2025, desde <https://support.blackberry.com/kb/articleDetail?articleNumber=000082334>
- CrowdStrike. (2024). *2024 Global Threat Report*. CrowdStrike Inc. Consultado el 29 de agosto de 2025, desde <https://www.crowdstrike.com/resources/reports/global-threat-report/>
- Cybersecurity and Infrastructure Security Agency. (2024). *Transportation Systems Sector*. CISA. Consultado el 29 de agosto de 2025, desde <https://www.cisa.gov/topics/critical-infrastructure-security-and-resilience/critical-infrastructure-sectors/transportation-systems-sector>
- Der Spiegel. (2024). *Datenpanne bei VW: Standortdaten von 800.000 E-Autos offen im Internet*. Der Spiegel. Consultado el 29 de agosto de 2025, desde <https://www.spiegel.de/netzwelt/web/volkswagen-datenpanne-standortdaten-von-800-000-e-autos-offen-im-internet-a-8d7b6db7-0847-4c82-8aac-5e0a1e52eebc>
- European Union Agency for Cybersecurity. (2023). *ENISA Threat Landscape 2023*. ENISA. Consultado el 29 de agosto de 2025, desde <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2023>
- Fortinet PSIRT. (2024). *FortiOS SSL-VPN Heap-Based Buffer Overflow Vulnerability (FG-IR-24-015)*. Fortinet Inc. Consultado el 29 de agosto de 2025, desde <https://www.fortiguard.com/psirt/FG-IR-24-015>
- Kovacs, E. (2022). *Continental Cyber Incident: What We Know So Far*. SecurityWeek. Consultado el 29 de agosto de 2025, desde <https://www.securityweek.com/continental-says-hackers-stole-data-in-recent-cyberattack/>
- Kovacs, E. (2024). *Volkswagen Cariad Data Breach Exposed Location of 800,000 EVs*. SecurityWeek. Consultado el 29 de agosto de 2025, desde <https://www.securityweek.com/volkswagen-cariad-data-breach-exposed-location-of-800000-evs/>
- Mandiant. (2023). *APT41: A Dual Espionage and Cyber Crime Operation*. Mandiant Inc. Consultado el 29 de agosto de 2025, desde <https://www.mandiant.com/resources/apt41-dual-espionage-and-cyber-crime-operation>
- McKinsey & Company. (2024). *Automotive Software and Electrical/Electronic Architecture*. McKinsey & Company. Consultado el 29 de agosto de 2025, desde <https://www.mckinsey.com/industries/automotive-and-assembly/our-insights/automotive-software-and-electrical-electronic-architecture>
- Microsoft Security Response Center. (2024). *Microsoft Security Update Guide*. Microsoft Corporation. Consultado el 29 de agosto de 2025, desde <https://msrc.microsoft.com/update-guide/>
- MITRE Corporation. (2024a). *Akira (S1129) – MITRE ATT&CK*. MITRE Corporation. Consultado el 29 de agosto de 2025, desde <https://attack.mitre.org/software/S1129/>
- MITRE Corporation. (2024b). *APT41 (G0096) – MITRE ATT&CK*. MITRE Corporation. Consultado el 29 de agosto de 2025, desde <https://attack.mitre.org/groups/G0096/>
- MITRE Corporation. (2024c). *BlackCat/ALPHV (S1076) – MITRE ATT&CK*. MITRE Corporation. Consultado el 29 de agosto de 2025, desde <https://attack.mitre.org/software/S1076/>



- MITRE Corporation. (2024d). *KillNet (G1014) – MITRE ATT&CK*. MITRE Corporation. Consultado el 29 de agosto de 2025, desde <https://attack.mitre.org/groups/G1014/>
- MITRE Corporation. (2024e). *Lazarus Group (G0032) – MITRE ATT&CK*. MITRE Corporation. Consultado el 29 de agosto de 2025, desde <https://attack.mitre.org/groups/G0032/>
- National Institute of Standards and Technology. (2023). *Guide to Industrial Control Systems (ICS) Security – NIST SP 800-82 Rev. 3*. NIST. Consultado el 29 de agosto de 2025, desde <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-82r3.pdf>
- National Institute of Standards and Technology. (2024). *National Vulnerability Database (NVD)*. NIST. Consultado el 29 de agosto de 2025, desde <https://nvd.nist.gov/>
- Rockwell Automation. (2023). *Security Advisory SD1699: Remote Code Execution Vulnerabilities in ControlLogix Communications Modules*. Rockwell Automation. Consultado el 29 de agosto de 2025, desde <https://www.rockwellautomation.com/en-us/support/advisory.SD1699.html>
- SAE International. (2021). *ISO/SAE 21434: Road Vehicles – Cybersecurity Engineering*. SAE International. Consultado el 29 de agosto de 2025, desde https://www.sae.org/standards/content/iso_sae.21434/
- Soo, Z. (2023). *Toyota Says Data of 2.15 Million Customers in Japan Exposed for 10 Years*. Reuters. Consultado el 29 de agosto de 2025, desde <https://www.reuters.com/business/autos-transportation/toyota-says-data-21-million-customers-may-have-been-exposed-2023-05-12/>
- The Record by Recorded Future. (2023). *Akira Ransomware Attack on Yanfeng Disrupted Stellantis Production Lines*. Recorded Future News. Consultado el 29 de agosto de 2025, desde <https://therecord.media/akira-ransomware-yanfeng-automotive-stellantis>
- Toulas, B. (2023). *Yanfeng Automotive Interiors Hit by Akira Ransomware*. BleepingComputer. Consultado el 29 de agosto de 2025, desde <https://www.bleepingcomputer.com/news/security/akira-ransomware-hit-yanfeng-automotive-interiors-caused-stellantis-supply-chain-disruption/>
- Toulas, B. (2024). *Hyundai Motor Europe Hit by Black Basta Ransomware Attack*. BleepingComputer. Consultado el 29 de agosto de 2025, desde <https://www.bleepingcomputer.com/news/security/hyundai-motor-europe-hit-by-black-basta-ransomware-attack/>
- Toyota Motor Corporation. (2023). *Notice Regarding Vehicle Data Stored in a Cloud Environment*. Toyota Motor Corporation. Consultado el 29 de agosto de 2025, desde <https://global.toyota/en/newsroom/corporate/39285947.html>
- Upstream Security. (2024). *Global Automotive Cybersecurity Report 2024*. Upstream Security. Consultado el 29 de agosto de 2025, desde <https://upstream.auto/reports/global-automotive-cybersecurity-report/>
- Wilhoit, K., & Hilt, S. (2023). *Driving Security Into Connected Cars: Threat Model and Recommendations*. Trend Micro Research. Consultado el 29 de agosto de 2025, desde <https://www.trendmicro.com/vinfo/us/security/news/internet-of-things/driving-security-into-connected-cars-threat-model-and-recommendations>